

Normativa de Seguridad

Izertis

Marzo 2026

Internship Program

izertis

**YOUR FUTURE,
OUR CHALLENGE.**



Introducción

El objetivo de esta charla es acercar conceptos de seguridad, asimilarlos y ponerlo a prueba durante vuestra formación en el departamento.

Es imprescindible garantizar el uso de conocimientos de seguridad, tanto técnicos como organizativos a la hora de aplicarlos en los laboratorios.

Existen en España marcos normativos y guías técnicas que regulan cómo deben diseñarse y protegerse estos sistemas. Entre los más relevantes encontramos, por ejemplo:

- El Sistema de Información Clasificada (SIC).
- Las Guías CCN-STIC del Centro Criptológico Nacional.
- El Esquema Nacional de Seguridad (ENS) regulado por el Real Decreto 311/2022.

Llegados a este punto, nos metemos en materia aclarando unos conceptos fundamentales.

Conceptos fundamentales

- **CIS – Communications and Information Systems**

Es cualquier sistema formado por hardware, software, redes y procedimientos que permite procesar, almacenar o transmitir información.

Es importante destacar que un CIS no necesariamente maneja información clasificada.

Puede ser cualquier sistema informático, desde un servidor empresarial hasta una infraestructura más compleja.

- **SIC – Security of Classified Information**

Un SIC es un Sistema de Información Clasificada (un sistema autorizado específicamente para tratar información clasificada).

Esto implica que el sistema cumple normativa de seguridad específica, ha pasado procesos de acreditación y aplica controles de acceso más estrictos.

En resumen, todos los SIC son CIS, pero no todos los CIS son SIC.

Conceptos fundamentales

- **Información Clasificada**

La información clasificada es aquella cuya divulgación no autorizada podría afectar a la seguridad nacional o a intereses estratégicos y a la que se ha asignado una clasificación de seguridad. El acceso a esta información está restringido y controlado por autoridades competentes.

Para acceder a ella se aplican dos principios fundamentales: **la habilitación personal de seguridad y el principio de *need to know*.**

- **HPS (Habilitación Personal de Seguridad)**

Es la autorización que permite a una persona acceder a información clasificada hasta un determinado nivel (**HPS-N, HPS-UE, HPS-OTAN**), tras haber superado el oportuno proceso de acreditación de seguridad y haber sido adecuadamente concienciado en el compromiso de reserva que adquiere y en las responsabilidades que se derivan de su incumplimiento.

Sin embargo, tener HPS no significa que se pueda acceder a toda la información.

También debe cumplirse el principio de ***need to know***, es decir, que la persona necesite esa información para realizar su trabajo. periodo de validez de **cinco (5) años**.

Conceptos fundamentales

- **Instrucción de seguridad.**

Aquellas consignas y conocimientos que deben ser impartidos a cada individuo para mantenerle informado de las amenazas contra la seguridad, hacerle consciente de sus vulnerabilidades y concienciarle de sus responsabilidades para prevenir unas y otras. Es requisito previo para el acceso a la información clasificada.

- **Oficina Nacional de Seguridad (ONS).**

Integrado en el CNI, responsable de gestionar y expedir las habilitaciones personales de seguridad (HPS) como Materias Clasificadas del MDEF para empresas.



Conceptos fundamentales

- **Zonificación (ZAP & ZAR)**

En los sistemas que tratan información clasificada se utilizan zonas de seguridad para organizar el entorno.

- **ZAP (Zona Administrativa de Protección)**, que actúa como un perímetro de control antes de acceder al sistema. Almacena y maneja información hasta el grado de **DIFUSIÓN LIMITADA** inclusive como máximo.
- **ZAR (Zona de Alta Restricción)**, donde realmente se encuentran los equipos que procesan información clasificada. Son las instalaciones donde se almacena o maneja Información Clasificada de grado “**CONFIDENCIAL o equivalente**” o superior.

✓ **Área de Clase I:** La entrada a la zona supone, a todos los efectos, el acceso a la información clasificada.

✓ **Área de Clase II:** La IC está protegida del acceso de personas no autorizadas mediante controles establecidos internamente.

Esta separación permite aplicar controles físicos y lógicos más estrictos y facilita las auditorías de seguridad.

Información Clasificada

“Cualquier información o material respecto de la cual se decida que requiere protección contra su divulgación no autorizada y a la que se ha asignado una clasificación de seguridad”.

Materias Clasificadas: Ley 9/1968, de 5 de abril, modificada por la Ley 48/1978, de 7 de octubre, sobre Ley de Secretos Oficiales (LSO). **SECRETO y RESERVADO.**

Materias Objeto de Reserva Interna: **CONFIDENCIAL Y DIFUSIÓN LIMITADA.**

Una persona sólo podrá ser autorizada a acceder a la información clasificada de grado “CONFIDENCIAL o equivalente” o superior, cuando se hayan cumplido los siguientes requisitos:

- Le haya sido concedida una habilitación personal de seguridad (HPS) del nivel adecuado.
- Se haya determinado su “necesidad de conocer”.
- Haya recibido la instrucción de seguridad preceptiva.

***Nota:** La autorización para el acceso al grado de clasificación de información “DIFUSIÓN LIMITADA o equivalente” solo requiere la perceptiva necesidad de conocer, así como haber recibido la instrucción de seguridad necesaria. A pesar de ello, siempre es recomendable la obtención de la correspondiente HPS.*

Información Clasificada

Grados de clasificación en España

SECRETO: Se aplicará a la información que precise del más alto grado de protección, toda vez que su revelación no autorizada o utilización indebida, pudiera dar lugar a una amenaza o perjuicio extremadamente grave para la seguridad del Estado, o pudiera comprometer los intereses fundamentales de la nación en materia referente a la defensa nacional, la paz exterior o el orden constitucional.

RESERVADO: Se aplicará a la información que precise de un alto grado de protección, toda vez que su revelación no autorizada o utilización indebida, pudiera dar lugar a una amenaza o perjuicio grave a los referidos intereses de España.

CONFIDENCIAL: Se aplicará a la información cuya revelación no autorizada o utilización indebida, pudiera dar lugar a una amenaza o perjuicio a los intereses de España.

DIFUSIÓN LIMITADA: Se aplicará a la información cuya revelación no autorizada o utilización indebida, pudiera ser contraria a los intereses de España.

Información Clasificada

Protección de la información Clasificada. Seguridad Física

- La seguridad física debe aplicarse de forma **integral**, combinando medidas físicas con la seguridad del **personal, la información y los sistemas**.
- Se basa en un modelo de **defensa en profundidad**, con varios niveles de protección desde el exterior hasta la instalación final.
- **Entornos de seguridad:**
 - **EGS (Entorno Global de Seguridad):** perímetros exteriores que protegen el acceso a la zona restringida.
 - **ELS (Entorno Local de Seguridad):** medidas internas en accesos, paredes y zonas cercanas que impiden el acceso a información clasificada.
 - **ESE (Entorno de Seguridad Electrónico):** protección frente a fugas de información (TEMPEST y escuchas).
- Las instalaciones con información **CONFIDENCIAL o superior** deben acreditarse como **Zona de Acceso Restringido (ZAR)**.

Información Clasificada

Protección de la información Clasificada. Seguridad en el personal

Las medidas de seguridad en el personal garantizarán que las siguientes personas disponen de habilitación personal de seguridad:

- El personal que pertenece al órgano de control, es decir, el personal que está permanentemente asignado al mismo.
- Los usuarios de los documentos clasificados del organismo, empresa, etc., al que sirve dicho órgano de control.

Información Clasificada

Protección de la información Clasificada. Seguridad de la información

La seguridad de la información se obtiene cuando se aplica un conjunto de medidas y procedimientos para el correcto manejo de la información clasificada y para prevenir y detectar los posibles comprometimientos de esta, que puedan afectar a su confidencialidad, integridad o disponibilidad.

La información clasificada debe ser protegida y manejada a lo largo de todo su ciclo de vida de forma apropiada y acorde a su grado de clasificación.

Información Clasificada

Equivalencias

ESPAÑA	OTAN	UE	ESA
SECRETO (S)	COMIC TOP SECRET (CTS)	EU TOP SECRET/TRES SECRET UE (TS-UE)	ESA ESA TOP SECRET (ESA TS)
RESERVADO (R)	NATO SECRET (NS)	SECRET UE (S-UE)	ESA SECRET (ESA S)
CONFIDENCIAL (C)	NATO CONFIDENCIAL (NC)	CONFIDENTIEL UE (C-UE)	ESA CONFIDENTIAL (ESA C)
DIFUSION LIMITADA (DL)	NATO RESTRICTED (NR)	RESTREINT UE (R-UE)	ESA RESTRICTED (ESA R)
----	NATO UNCLASSIFIED	LIMITE UE	ESA UNCLASSIFIED

**Tanto CONFIDENCIAL como DIFUSIÓN LIMITADA se denominan “materias de reserva interna”. SECRETO y RESERVADO se consideran materias clasificadas en sentido estricto.*

Información Clasificada

Nunca debemos...

- Gestionar IC al margen de las indicaciones establecidas.
- Remitir IC por canales no autorizados.
- Extraer IC del ZAR donde se encuentre.
- Proporcionar IC o información sobre el proyecto a personas ajenas al propio proyecto, incluso siendo del mismo cliente.
- Hacernos cargo de IC: Transporte, Protección... (cualquier acción que haga que asumamos ser los responsables de IC).
- Conectar sistemas clasificados a Internet.
- Destruir IC sin autorización.
- Almacenar (gestionar, crear, etc.) IC en las instalaciones de IZT sin autorización previa.

Información Clasificada

Amenazas y vulnerabilidades

- Personas ajenas al proyecto o desconocidas solicitan información de este.
- Emitimos información hacia allegados, compañeros de trabajo u otras personas del cliente no conocidas.
- Nos piden que nos hagamos cargo de IC u otra tarea fuera del ámbito del proyecto.
- Desde un punto de vista de “amigo”, una persona (cliente, amigo, compañero) intenta sonsacar información.

Información Clasificada

MANEJO DE INFORMACIÓN CLASIFICADA									
GRADOS	DIFUSIÓN LIMITADA		CONFIDENCIAL		RESERVADO		SECRETO		Observaciones
Acceso	¿Qué es necesario para acceder a información clasificada?								
Necesidad de conocer	SÍ		SÍ		SÍ		SÍ		Acreditada por el jefe directo
Habilitación Personal de Seguridad (HPS)	NO		SÍ		SÍ		SÍ		Del grado adecuado a la información
Instrucción en seguridad	SÍ		SÍ		SÍ		SÍ		Certificada por el Jefe del Órgano de Control.
Manejo, almacenamiento y custodia	¿Dónde y cómo se ha de manejar la información clasificada?								
En una Zona de Acceso Restringido	SÍ		SÍ		SÍ		SÍ (excepto contratistas)		Del grado adecuado a la información
En una Zona Administrativa de Protección	SÍ		SÍ, con autorización del jefe de seguridad		SÍ, con carácter limitado en horario laboral		NO		
Fuera de cualquier Zona de Seguridad	SÍ		SÍ, con autorización del jefe de seguridad		NO		NO		
Necesidad de compartimentación	Por tipo	Por grado	Por tipo	Por grado	Por tipo	Por grado	Por tipo	Por grado	Aunque no sea necesaria la compartimentación, siempre es conveniente.
	NO, pero conveniente	NO	SÍ	NO, pero conveniente	SÍ	SÍ	SÍ	SÍ	
Control permanente e individualizado de cada documento	NO		SÍ		SÍ (imputable)		SÍ (imputable)		
Necesidad de comunicar al Registro Central las variaciones de una información (alta, destrucción, transmisión)	NO		NO		NO		SÍ		
Necesidad de acreditación de sistemas CIS de almacenaje	SÍ		SÍ		SÍ		SÍ		
Transmisión	¿Cómo se transmite la información clasificada?								
A través del sistema de registro de órganos de control	SÍ, pero puede circular entre usuarios		SÍ		SÍ		SÍ		Contratistas: la información clasificada de DL ha de circular siempre a través de órganos de control.
Sobres y paquetes	Cualquier medio que evite la evidencia del contenido		Sistema de dobles sobres (opacos, resistentes y cerrados con precintos)						
Recibos de recepción	NO necesario		SÍ (sólo de transporte)		SÍ *		SÍ *		* Obligatorios los recibos de transporte y de remitente
Por sistemas CIS o soportes cifrados	SÍ, por sistemas acreditados y medios aprobados		SÍ, por sistemas acreditados y medios aprobados		SÍ, por sistemas acreditados y medios aprobados		SÍ, por sistemas acreditados y medios aprobados		
Transporte	Es una transmisión por medios físicos, ¿cómo se puede hacer?								
	Nacional	Internacional	Nacional	Internacional	Nacional	Internacional	Nacional	Internacional	
	SÍ	SÍ	SÍ	SÍ	SÍ	SÍ	SÍ, con autorización	SÍ, bajo ciertas condiciones	
Mediante correo autorizado o valija conducida por personal funcionario	SÍ	SÍ	SÍ	SÍ	SÍ	SÍ	SÍ, con autorización	SÍ, bajo ciertas condiciones	
Mediante valija militar o gubernamental, no									

Marco Normativo en España

- **CNI**

Organismo del Estado que, en base lo establecido en el artículo 4º apartado f de la Ley 11/2002 de 6 de mayo reguladora del Centro Nacional de Inteligencia, es responsable de “Velar por el cumplimiento de la normativa relativa a la protección de la Información Clasificada”.

- **Centro Criptológico Nacional (CCN)**

El Centro Criptológico Nacional, dependiente del CNI, es el organismo responsable de definir políticas de seguridad TIC para el sector público.

Además, desarrolla guías técnicas y coordina la respuesta ante incidentes de ciberseguridad a través del CCN-CERT.

- **Guías CCN-STIC**

Las guías CCN-STIC son documentos técnicos que establecen recomendaciones de seguridad para proteger sistemas de información. Estas guías cubren diferentes áreas como el bastionado de sistemas, la seguridad en redes, la gestión de identidades o la monitorización. En muchos proyectos sirven como referencia para aplicar configuraciones seguras y realizar auditorías.

Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

El Esquema Nacional de Seguridad establece los requisitos mínimos y marco común de la seguridad de la información y los servicios que deben cumplir los sistemas de información del sector público de España. Lo regula el **Real Decreto Ley 311/2022**.

El **ENS** es una ley de obligado cumplimiento para el sector público, estableciendo así un marco común de seguridad para la protección de la información que manejan las administraciones públicas, así como los servicios que prestan.

Por lo tanto, la Administración General de Estado, las Administraciones de las comunidades autónomas y las Entidades que integren la Administración local deben cumplir esta normativa. Sin embargo, también deberán cumplirla fundaciones del sector público, hospitales y universidades públicas, cámaras de comercio, federaciones deportivas, etc.

Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

Su objetivo es garantizar la protección de la información y la continuidad de los servicios, además de generar un nivel suficiente de confianza en el uso de los medios electrónicos a través de una serie de medidas que garanticen la seguridad de los sistemas, datos, comunicaciones y servicios electrónicos; permitiendo así a los ciudadanos y administraciones públicas no solo el ejercicio de sus derechos sino también el cumplimiento de sus deberes.

El ENS es gestionado y liderado por el CCN-CERT (Equipo de Respuesta ante Incidentes de Seguridad de la Información del Centro Criptológico Nacional), que se encarga de contribuir a la ciberseguridad de los organismos públicos.



Marco Normativo en España

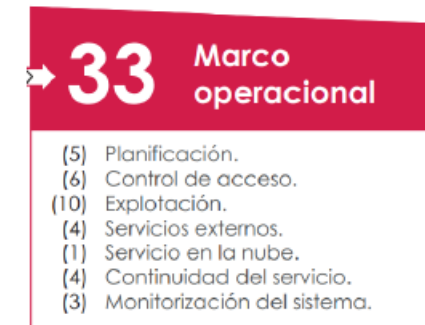
- **Esquema Nacional de Seguridad (ENS)**

El ENS consta de **73 medidas** divididas en tres grupos:

Marco organizativo [org.]: Constituido por el conjunto de medidas relacionadas con la organización global de la seguridad. Se trata de un marco relacionado con las políticas, la normativa y los documentos relacionados con la seguridad de la información recogido en cuatro medidas.



Marco operacional [op.]: Incluye las medidas a tomar para proteger la operación del sistema como conjunto integral de componentes para un fin. Consta de 33 medidas recogidas en siete bloques diferentes, siendo estos planificación, control de acceso, explotación, servicios externos, servicios en la nube, continuidad del servicio y monitorización del sistema.



Marco Normativo en España

- Esquema Nacional de Seguridad (ENS)

Medidas de protección [mp.]: Se centran en proteger activos concretos, según su naturaleza y la calidad exigida por el nivel de seguridad de las dimensiones afectadas. Recoge 36 medidas agrupadas en ocho bloques, siendo estos protección de las instalaciones e infraestructuras, gestión del personal, protección de los equipos, protección de las comunicaciones, protección de los soportes de información, protección de las aplicaciones informáticas, protección de la información y protección de los servicios.



Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

Otro concepto que debemos conocer son las dimensiones de seguridad, que nos permitirán determinar el impacto que un incidente que afecte a la seguridad de la información o de los sistemas tendría sobre la organización. Estas dimensiones de seguridad son:

- **Disponibilidad [D]:** Se refiere a las consecuencias que derivan de que una persona autorizada no pueda acceder a la información cuando lo necesita.
- **Autenticidad [A]:** Hace referencia a las consecuencias de que la información no fuera auténtica.
- **Integridad [I]:** Las consecuencias de una modificación de la información por alguien no autorizado.
- **Confidencialidad [C]:** Se trata de las consecuencias que tendría el acceso a la información por personas no autorizadas.
- **Trazabilidad [T]:** Hace referencia a las consecuencias de no poder rastrear a posteriori quién ha accedido o modificado una información.

Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

Una vez que hemos conocido las dimensiones de seguridad, debemos categorizar los sistemas con el objetivo de determinar las medidas de seguridad aplicables en función de la información que se maneja, los servicios que prestan y los riesgos a los que están expuestos. Para ello, encontramos tres escalones de categorización en función del impacto que tendría un incidente que afectara a la seguridad de la información o a los servicios en alguna de las dimensiones:

- **Nivel bajo:** Cuando el impacto o las consecuencias de un incidente de seguridad suponga un perjuicio limitado sobre las funciones de la organización, sus activos o sobre los individuos afectados.
- **Nivel medio:** Hace referencia a un perjuicio grave.
- **Nivel alto:** Se trata de un perjuicio muy grave.

Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

Conociendo las dimensiones y los niveles de impacto que pueden tener los sistemas, vamos a determinar la categoría de los mismos en:

- **Categoría básica:** Un sistema de información será de categoría básica si alguna de las dimensiones de seguridad alcanza el nivel bajo y ninguna uno superior.
- **Categoría media:** Será de categoría media si alguna de las dimensiones alcanza el nivel medio y ninguna de ellas alcanza uno superior.
- **Categoría alta:** Será de categoría alta si alguna de las dimensiones alcanza el nivel alto.

Marco Normativo en España

- **Esquema Nacional de Seguridad (ENS)**

Algunas de las **ventajas** que pueden tener las organizaciones si cumplen correctamente con el Esquema Nacional de Seguridad son:

- La reducción del riesgo de sufrir pérdidas o manipulaciones de la información de los sistemas de la organización.
- La revisión continua y periódica de los riesgos existentes a los que están expuestos los sistemas de información.
- La implantación de medidas de seguridad, que genera confianza en la relación con los clientes, los socios estratégicos y los proveedores.
- La optimización de los procesos y procedimientos de la información, reduciendo así los costes asociados a los mismos.

Marco Normativo en España

Esquema Nacional de Seguridad (ENS)	
Norma jurídica	Real Decreto Ley 311/2022.
Obligatoriedad	Sí, para la Administración General del Estado, las administraciones de las comunidades autónomas y las entidades que integran la Administración Local, así como para entidades del sector público, como fundaciones, universidades y hospitales públicos etc., y empresas del sector privado, así como cadenas de suministro de empresas del sector privado que presten servicio a entidades públicas.
Ámbito de aplicación	Nacional.
Objetivo	Proporciona los principios básicos y requisitos mínimos que necesitan cumplir las organizaciones para lograr una protección adecuada de la información y el servicio que prestan, con el objetivo de garantizar el acceso, la confidencialidad, la integridad, la trazabilidad, la autenticidad, la disponibilidad y la conservación de los datos, información y servicios.
Ventajas de su implementación	Reducción del riesgo de sufrir pérdidas o manipulaciones de la información, revisión continua y periódica de los riesgos, implantación de medidas de seguridad, optimización de procesos y procedimientos, reducción de costes, etc.
Figura(s) Responsable(s)	Responsable de la información, responsable del servicio, responsable de seguridad y responsable del sistema.
Certificable	Sí.

Marco Normativo en Europa

NIS (Security of Network and Information Systems)

- Directiva europea creada para **garantizar un alto nivel de seguridad en redes y sistemas de información en la UE (Directiva (UE) 2022/2555 – NIS2)**.
- Surge debido al **aumento de incidentes de ciberseguridad** que afectan a servicios esenciales.
- Busca **armonizar la seguridad entre los Estados miembros** mediante requisitos comunes.

Tiene como objetivos:

- Establecer **estrategias nacionales de ciberseguridad** en cada país.
- **Fomentar la cooperación** e intercambio de información entre Estados miembros.
- Crear una **red europea de CSIRT** (equipos de respuesta a incidentes).
- Definir **requisitos de seguridad comunes** para servicios esenciales y servicios digitales.

Marco Normativo en Europa

NIS (Security of Network and Information Systems)

Afecta a

- **Operadores de Servicios Esenciales (OSE)** → Entidades públicas o privadas que prestan **servicios críticos para la sociedad o la economía**.
- **Proveedores de Servicios Digitales (PSD)** → Empresas que prestan **servicios digitales por vía electrónica** a cambio de remuneración.

Evolución de la directiva a NIS2 → La nueva versión propone:

Requisitos de seguridad más estrictos.

Mayor control de la **cadena de suministro**.

Responsabilidad de la alta dirección en ciberseguridad.

Procedimientos más claros de **notificación de incidentes**.

Ampliación de **sectores afectados** (alimentación, telecomunicaciones, fabricación, administración pública, etc.).

Marco Normativo en Europa

NIS (Security of Network and Information Systems)

En cuanto a España, la Directiva NIS se aplica en España mediante:

Real Decreto-Ley 12/2018 de Seguridad de las Redes y Sistemas de Información (base legal).

Real Decreto 43/2021 (desarrollo reglamentario).

Esta norma:

- Define el régimen de seguridad nacional.
- Establece las **autoridades competentes**.
- Regula **sanciones por incumplimiento**.

*La Directiva NIS establece un **marco común europeo de ciberseguridad**, obligando a operadores críticos y servicios digitales a **gestionar riesgos, proteger sistemas y notificar incidentes**, garantizando así la **continuidad de servicios esenciales y la cooperación entre países**.*

Marco Normativo en Europa

NIS (Security of Network and Information Systems)

Directiva NIS (Security of Network and Information Systems)	
Norma jurídica	Directiva europea. Transposición a nivel nacional a través del Real Decreto Ley 12/2018 de Seguridad de las Redes y Sistemas de Información.
Obligatoriedad	Sí, para los operadores de servicios esenciales (OSE) establecidos en España y los proveedores de servicios digitales (PSD) establecidos en España y los que, aun no estando establecidos en la UE, designen en España a su representante para el cumplimiento de la Directiva.
Ámbito de aplicación	Directiva NIS: europeo. Real Decreto Ley 12/2018: nacional.
Objetivo	Unificar la disparidad de niveles de protecciones de las redes y sistemas de información, estableciendo una serie de requisitos comunes relativos al desarrollo de las capacidades y planificación, el intercambio de información, la cooperación entre países y los requisitos comunes de seguridad necesarios para los diferentes operadores de servicios esenciales y proveedores de servicios digitales.
Ventajas	Marco común europeo para la protección de redes y sistemas de información, cooperación entre países e intercambio de información.
Figura(s) Responsable(s)	Responsable de Seguridad de la Información (RSI)
Certificable	No.

Proceso de creación de un CIS

- **Puesta en contexto del proyecto**

Cuando se inicia un proyecto lo primero es entender el contexto.

Se analizan los requisitos del cliente, el alcance del sistema y la infraestructura prevista.

Con esta información se identifican los activos del sistema y las necesidades de seguridad.

- **Diseño del sistema**

En la fase de diseño se define la arquitectura del sistema.

Esto incluye el diagrama de red, la segmentación de la infraestructura, los servidores, los dispositivos de red y las comunicaciones.

El objetivo es tener una visión clara de cómo va a funcionar el sistema.

Proceso de creación de un CIS

- **Análisis de Riesgos**

Una vez diseñado el sistema se realiza un análisis de riesgos.

Este análisis permite identificar amenazas, vulnerabilidades y posibles impactos sobre el sistema.

En muchos proyectos se utiliza la metodología MAGERIT y herramientas como PILAR.

>>> **Metodología MAGERIT** → Es una **metodología de análisis y gestión de riesgos** para sistemas de información (muy usada en España, especialmente en entorno público/ENS).

MAGERIT no es una “herramienta”; es un **marco de trabajo**: te dice **cómo** analizar riesgos de forma consistente.

>>> **Herramientas PILAR** → Es una **herramienta** (software) que **implementa MAGERIT** y te ayuda a:

modelar activos y dependencias, aplicar catálogos de amenazas, valorar impactos, calcular riesgos automáticamente, registrar salvaguardas y su eficacia además de generar informes.

Bastionado

- Prebastionado.
- Bastionado.
- Comprobaciones y análisis de vulnerabilidades.

Documentación de Seguridad

- **Diagrama de red**

Representación gráfica de la arquitectura del sistema de información.

Permite visualizar cómo están conectados los distintos componentes tecnológicos y cómo circula la información entre ellos, incluyendo servidores, dispositivos de red y segmentación.

- **Análisis de Riesgos**

Documento mediante el cual se identifican y evalúan los riesgos que pueden afectar a un sistema de información.

Se identifican activos del sistema, amenazas, vulnerabilidades, impacto sobre los activos del sistema y probabilidad.

El objetivo es **determinar el nivel de riesgo y definir medidas de seguridad para reducirlo a un nivel aceptable.**

Documentación de Seguridad

- **CO – Concepto Operacionales**

definen cómo se organiza y gestiona la seguridad dentro del sistema desde el punto de vista operativo y organizativo.

Incluyen aspectos como:

Roles y responsabilidades de seguridad, procedimientos de gestión de incidentes, normas de uso de los sistemas, gestión de accesos y usuarios además de procedimientos de mantenimiento y operación.

Los CO ayudan a establecer **cómo deben actuar las personas y los procesos para mantener la seguridad del sistema de forma continua.**

Documentación de Seguridad

- **COS – Concepto Operacional de Seguridad**

Describe cómo se implementará la seguridad del sistema en su funcionamiento diario.

Este documento integra:

Los controles de seguridad definidos, procedimientos de protección y monitorización, la forma en que se gestionarán incidentes de seguridad y la relación entre los distintos componentes del sistema y las medidas de seguridad aplicadas.

En otras palabras, el COS explica **cómo se aplican en la práctica las políticas y controles de seguridad dentro del sistema.**

Documentación de Seguridad

- **DRS – Documento de Requisitos de Seguridad**

Establece los requisitos de seguridad que debe cumplir el sistema antes de su desarrollo o implementación.

En este documento se definen:

Controles de seguridad obligatorios, requisitos de **confidencialidad, integridad y disponibilidad de la información**, medidas de protección técnicas (cifrado, autenticación, control de acceso, etc.), requisitos normativos o regulatorios que deben cumplirse y niveles de seguridad que debe alcanzar el sistema.

El DRS sirve como **referencia para diseñar, implementar y evaluar la seguridad del sistema**, asegurando que cumple con las políticas y normativas establecidas.

Documentación de Seguridad

- **DRES - Documento de Requisitos Específicos de Seguridad**

El DRES complementa al DRS y recoge **requisitos de seguridad más detallados (específicos) del sistema o de un componente concreto.**

En este documento se especifican aspectos como:

Configuraciones técnicas concretas, controles adicionales para determinados activos, medidas específicas derivadas del análisis de riesgos y requisitos particulares del entorno o del proyecto

El DRES permite **adaptar los requisitos de seguridad generales del DRS a las características específicas del sistema.**

Documentación de Seguridad

- **POS – Procedimiento Operativos de Seguridad**

Describe de forma detallada **cómo se aplican en la práctica los controles y medidas de seguridad durante la operación diaria del sistema**. Estos procedimientos sirven como guía para el personal encargado de administrar o utilizar el sistema, asegurando que las actividades se realizan siguiendo las políticas de seguridad establecidas. Normalmente incluyen:

- **Procedimientos de gestión de accesos** (creación, modificación y eliminación de usuarios).
- **Gestión de incidentes de seguridad**, indicando cómo detectarlos, notificarlos y responder ante ellos.
- **Procedimientos de copia de seguridad y recuperación** ante fallos o pérdidas de información.
- **Actualización y mantenimiento de sistemas**, incluyendo parches de seguridad.
- **Monitorización y registro de eventos de seguridad + Procedimientos ante situaciones de emergencia o contingencias**.

El objetivo de los POS es **garantizar que los controles de seguridad definidos en la organización se aplican correctamente en el día a día y de forma uniforme por todo el personal**.

Documentación de Seguridad

- **DRSI – Declaración de Requisitos de Seguridad de Interconexión**

Es un documento que se utiliza cuando **un sistema de información se conecta o intercambia datos con otros sistemas o redes externas**. Su función principal es **definir las condiciones y medidas de seguridad necesarias para garantizar que esa interconexión no compromete la seguridad de los sistemas involucrados**. En la DRSI se suelen especificar:

- **Sistemas que se interconectan** y el propósito de la conexión.
- **Tipo de información que se intercambia** entre los sistemas.
- **Medidas de seguridad aplicadas a la conexión**, como cifrado, autenticación o control de acceso.
- **Protocolos y mecanismos de comunicación utilizados**.
- **Responsabilidades de cada organización o sistema conectado**.
- **Medidas de monitorización y control de la interconexión**.

Este documento es especialmente importante cuando se conectan **sistemas de diferentes organizaciones o infraestructuras críticas**, ya que ayuda a mantener la seguridad y la confianza entre las partes.

Comprobaciones finales y buenas prácticas

Antes de cualquier entrega de un sistema se realizan revisiones tales:

- Funcionamiento del sistema y verificación de configuraciones.
- Validación de servicios y entregables.
- Revisión de documentación.

Esto garantiza que el sistema está **listo para su acreditación y operación segura**. Así mismo, como recomendaciones clave:

- Versionado de documentación y trazabilidad de cambios.
- Trabajo colaborativo.
- Proactividad e iniciativa.
- Metodología clara y feedback.

Dudas y preguntas



izertis.com

